DOKUMEN KEAMANAN SISTEM & KEPATUHAN PDP (03_SECUR

PROYEK: SISTEM MANAJEMEN INVENTARIS UMKM NUSANTARA (PRJ-WIDYA-INV

Kode Proyek: `PRJ-WIDYA-INV-02`

Disusun Oleh: `agen_keamanan` (SOP-07: Penjaminan Kepatuhan Regulasi & Keamanan Siber)

Disetujui Oleh: `agen_orkestrator` & `agen_arsitek`

Status: DISETUJUI * ZERO DATA LEAKAGE COMPLIANT

1. Kepatuhan Undang-Undang Perlindungan Data Pribadi (UU No. 27/2022)

Meskipun sistem berfokus pada inventaris fisik barang dagangan, sistem menyimpan data personel gudang, pemasok pihak

Kategori Data	Elemen Data	Klasifikasi UU PDP	Kebijakan Perlindungan
**Data Operator Gu...	Nama Operator, NIK...	Data Pribadi Umum	Masking NIK (`3302...
**Data Kontak Pema...	No. Telepon / What...	Data Pribadi Umum	Enkripsi kolom at-...
**Data Mutasi Fina...	Harga Perolehan, N...	Rahasia Dagang UMKM	Akses dibatasi per...

2. Standar Kriptografi & Integritas Data

1. **Penyimpanan Basis Data (Data at-Rest)**:

- File basis data `data.wdb` dilindungi izin akses berkas POSIX mode `0600` (eksklusif user pengembang).

- Seluruh mutasi barang diverifikasi menggunakan hash berantai SHA-256 untuk mendeteksi rekayasa kartu stok opname.

2. **Komunikasi Data (Data in-Transit)**:

- Komunikasi portal RFID reader ke web dashboard menggunakan HTTP/WebSocket terlindungi header token sesi aman.

- Siap TLS 1.3 dengan sertifikat x509 lokal berstandar Post-Quantum Cryptography (PQC Kyber/Dilithium) bila diakses anta

3. Matriks Kontrol Akses Berbasis Peran (RBAC)

Peran (Role)	Lihat Stok & Rak	Pindai Barcode	Operasikan RFID Gate	Rekonsiliasi Opname	Kelola Master SKU
**Operator...	[OK]	[OK]	[OK]		
**Auditor ...	[OK]	[OK]	[OK]	[OK] (Draft)	
**Warehous...	[OK]	[OK]	[OK]	[OK] (App...	[OK]
**Administ...	[OK]	[OK]	[OK]	[OK]	[OK]

4. Mitigasi Risiko OWASP Top 10

1. **SQL Injection**:

- Engine WidyaBase memisahkan parser AST dan eksekusi kueri parametrik. Tidak ada dynamic string concatenation pada

2. **Cross-Site Scripting (XSS)**:

- Seluruh konten dinamis yang dirender ke tabel DOM `app.js` menggunakan sanitasi teks `textContent` dan encoding entita

3. **Path Traversal**:

- Server web mandiri `server.wya` membatasi pengiriman berkas statis hanya dalam direktori `./web` yang di-jail. Berkas de

4. **Secret & Key Leakage**:

- Tidak ada token rahasia atau kunci API hardcoded pada berkas publik (`app.js`, `index.html`, `server.wya`).